# Acme Cloud — Information Security Policy (Fictional sample document)

*Security policy for a fictional company, Acme Cloud, used to demo DocuMind.*

## 1. Passwords and multi-factor authentication

Passwords must be at least 14 characters long. Password managers are mandatory for all staff; the approved password manager is provided by IT. Passwords must never be shared, including with IT staff.

Multi-factor authentication (MFA) is required for email, the VPN, cloud consoles and source code hosting. Hardware security keys are required for administrators of production systems.

## 2. Access control

Access follows the principle of least privilege: employees get only the access their role needs. Access to production databases requires a ticket approved by the system owner and expires automatically after 8 hours.

Access reviews are performed every quarter by each system owner. Accounts of employees who leave the company are disabled within 4 hours of their exit.

## 3. Data classification

Acme Cloud classifies data into four levels:

• **Public** — may be shared freely (marketing pages).

• **Internal** — for employees only (internal wiki).

• **Confidential** — customer data and contracts; encrypted at rest and in transit.

• **Restricted** — secrets such as encryption keys and API credentials; stored only in the secrets manager.

Confidential and restricted data must never be pasted into public AI chatbots or external tools that are not approved by the security team.

## 4. Incident response

Any suspected security incident must be reported to security@acme.example or the #sec-incidents channel within 1 hour of discovery.

Severity levels:

• **SEV-1**: customer data exposed or production down. Incident commander assigned within 15 minutes; customers notified within 72 hours if their data is affected.

• **SEV-2**: a security control has failed but no data was exposed. Response within 4 hours.

• **SEV-3**: low-risk issue such as a phishing email that was not clicked. Response within 2 working days.

A blameless post-incident review is written for every SEV-1 and SEV-2 incident within 5 working days.

## 5. Secure development

• All code changes require review by at least one other engineer before merging.

• Dependencies are scanned for known vulnerabilities on every pull request; critical vulnerabilities must be fixed within 7 days.

• Secrets must never be committed to git. Leaked secrets must be rotated immediately.

• User input must be validated on the server side, and database queries must use parameterised statements to prevent SQL injection.

## 6. Devices

Company laptops must use full-disk encryption and lock automatically after 5 minutes of inactivity. Lost devices must be reported within 1 hour so they can be wiped remotely.

## 7. Phishing

Employees complete phishing-awareness training when they join and every 6 months after that. Suspicious emails should be reported with the "Report phishing" button, not forwarded.